Procédure interne de gestion des failles et violations de données

Livrable du projet T-LAW-901

Réalisé par Justin MBODJE, Yasser MEKHFI, Jérémy COQUELIN, Mohamed FOFANA, Matteo COGAN, Romain CROCQ-MARCHAND, Tristan CHARDES

Établissement de formation : EPITECH RENNES

Promotion 2026

Objectif :

Définir un protocole clair pour détecter, contenir, évaluer et notifier toute violation de données personnelles, conformément aux obligations du RGPD (articles 33-34) et aux recommandations de la CNIL. CNIL+2CNIL+2

Étapes de la procédure

1. **Détection & signalement immédiat**
   - Tout incident (accès non autorisé, fuite, altération, divulgation, perte de disponibilité, attaque) est potentiellement une violation. cdg30.fr+1
   - Tout membre de l'équipe (technique, support, admin) peut signaler une suspicion via un canal interne défini (mail, ticket, hotline).

2. **Contenir l'incident**
   - Suspendre l'accès au système affecté (fermeture des sessions, revocation des clés, isolation des serveurs).
   - Sauvegarder et sécuriser les logs relatifs à l'incident (accès, changements, métadonnées).
   - Mettre en place des mesures immédiates pour éviter de nouvelles exfiltrations (pare-feu, blocage, patch, segmentation).

3. **Analyse de l'impact**
   - Identifier les données concernées (catégories, sensibilité, personnes potentiellement affectées).
   - Estimer l'ampleur de la violation (nombre d'utilisateurs, enregistrements, type de données).
   - Évaluer le risque pour les droits et libertés des personnes (données de santé → risque élevé).

4. **Notification à la CNIL**
    - Si la violation présente un risque pour les droits et libertés, notifier la CNIL dans les **72 heures maximum** après la détection. CNIL+1
    - Utiliser le formulaire officiel de notification (service en ligne). CNIL+1
    - Fournir les informations requises : nature de la violation, catégories de données, nombre approximatif de personnes concernées, conséquences probables, mesures prises ou envisagées, coordonnées du DPO / contact. Baker McKenzie Resource Hub+1

5. **Information des personnes concernées**
    - Si le risque est élevé (données sensibles exposées, divulgation non chiffrée), informer les utilisateurs concernés “sans retard indu”. Bird & Bird+1
    - Le message doit être clair, explicite, indiquer ce qui s’est passé, les mesures prises, et les contacts pour plus d’information.

6. **Mesures correctives & remédiation**
    - Corrections techniques : patch, renforcement sécurité, suppression accès compromis, rotation des clés, renforcement chiffrement, mise à jour des configurations.
    - Audit post-incident : revue de la cause, des logs, des vulnérabilités, améliorations des processus.
    - Mise à jour du registre des traitements si nécessaire (modification des flux, des prestataires, des mesures).
    - Formation / sensibilisation interne si l’incident est humain (erreur, négligence).

7. **Archivage & traçabilité**
    - Créer un “dossier incident” : timeline, logs, captures, décisions internes, échanges, rapport CNIL, notification aux utilisateurs.
    - Conserver ce dossier pendant au moins 5 ans (recommandé).